Astana IT University
School of Software Engineering

Diploma Project

Development of a System for Detecting and Anonymizing Personal Data Before Sending Text to Artificial Intelligence Services

Requirements Specification

Authors: Dossan Amina, Abzhamal Nazerke
Educational programme: Software Engineering
Supervisor: Sakhipov A.A., PhD,
Assistant Professor

Astana, 2026

Contents

1 Introduction **3**

1.1 Purpose 3

1.2 Sources of Requirements 3

1.3 Definitions 4

2 Stakeholders and User Roles **4**

3 System Overview **5**

4 Personal Data Categories **5**

5 Use Cases **6**

6 Functional Requirements **6**

7 Non-Functional Requirements **11**

8 Constraints and Assumptions **12**

9 Requirements Derived from the User Survey **13**

10 Traceability **14**

1. Introduction

1.1. Purpose

This document specifies the functional and non-functional requirements for the PII Anonymization Gateway, a system that detects personal data in text before it is sent to external artificial intelligence (AI) services, replaces the data with reversible pseudonyms and restores the original values in the response. The requirements are the basis for the design, the user interface prototype, the implementation and the evaluation of the system.

1.2. Sources of Requirements

The requirements were derived from the following sources:

- the project proposal, which defines the aim, objectives and scope of the project;
- the Law of the Republic of Kazakhstan "On Personal Data and Their Protection" [1], which regulates the processing and cross-border transfer of personal data;
- the literature review, in particular the prompt sanitization prototypes Casper [2] and PromptShield [3] and the Kazakh named entity recognition dataset KazNERD [4];
- the comparison of existing systems, including the experiment with Microsoft Presidio [5], which showed that individual identification numbers (IIN) were not recognized without customization;
- the user survey ($n = 35$) described in the document *Evidence of Relevance*;
- the technology comparison, where the first versions of FR-1–FR-5 and NFR-1–NFR-3 were used as decision criteria.

The identifiers FR-1–FR-5 and NFR-1–NFR-3 keep the meaning they have in the technology comparison; this document details them and adds the remaining requirements.

1.3. Definitions

Table 1: Terms and abbreviations

Term	Definition
Personal data	Information relating to an identified or identifiable natural person [1]
IIN / BIN	Individual identification number / business identification number: 12-digit identifiers used in Kazakhstan, containing a check digit
Pseudonym	A placeholder such as `<PERSON_1>` that replaces a detected value; the same entity receives the same pseudonym within one request
Mapping	The correspondence between pseudonyms and original values for one request, required for restoration
Policy	The action applied to a data type: replace, warn or block
Fail-closed	Behaviour in which text is not sent to the AI service if it could not be checked
NER	Named entity recognition
Recall / precision	The share of personal data values found by the system / the share of detections that are correct

2. Stakeholders and User Roles

The system distinguishes four roles (Table 2). Roles are assigned by the administrator; the user interface and the server enforce them.

Table 2: User roles

Role	Description	Access
User	Employee or student who sends text to ChatGPT or Gemini through the browser extension	Browser extension only
Administrator	Information security specialist who configures the system	Policies, users and roles, security settings, log and statistics
Auditor	Person who monitors compliance without changing settings	Log and statistics, read-only
Service account	Internal system of the organization (for example, a CRM or chatbot) that calls a language model programmatically	API proxy only

3. System Overview

The system consists of four components deployed within the organization's infrastructure:

1. *Anonymization service* (server): detects personal data, creates pseudonyms, stores the mapping and restores responses; it exposes a REST interface.
2. *Browser extension*: intercepts text in the web interfaces of ChatGPT and Gemini, shows the detected data, sends the anonymized text and restores the response on the page.
3. *API proxy*: provides an interface compatible with the programming interfaces of OpenAI and Gemini for service accounts.
4. *Administration panel*: web interface for policies, users, security settings, the log and statistics.

Only anonymized text leaves the organization. Original values and the mapping remain on the organization's server.

4. Personal Data Categories

Table 3 lists the data types the system must detect. Organization names are not personal data in the narrow sense, but they are included because, together with a BIN or a contract number, they can identify a sole proprietor or the client of a small company.

Table 3: Supported data types

Data type	Pseudonym	Detection method	Validation
Full name	`PERSON`	NER model (Kazakh, Russian, English) and a Kazakh name gazetteer	—
IIN	`IIN`	Pattern of 12 digits	Check digit, valid date of birth
BIN	`BIN`	Pattern of 12 digits with context	Check digit
Phone number	`PHONE`	Kazakhstan formats (+7, 8, operator codes)	Length and code
E-mail address	`EMAIL`	Pattern	Domain format
Postal address	`ADDRESS`	NER model and patterns (street, avenue, building, apartment)	—
Identity document number	`ID_DOC`	Pattern of 9 digits with context	Context words
IBAN	`IBAN`	Pattern "KZ" and 18 characters	IBAN checksum
Bank card number	`CARD`	Pattern of 16 digits	Luhn algorithm
Organization name	`ORG`	NER model and legal forms (LLP, JSC, IE)	—

Health data were mentioned by 20% of survey respondents. They are not included in the initial scope, which focuses on direct identifiers, and are recorded as a candidate category

for future work.

5. Use Cases

Table 4: Main use cases

ID	Use case	Main flow	Actor
UC-1	Send a request with personal data	The user types or pastes text; the extension highlights the detected data; the user reviews them, edits them if necessary and confirms; the anonymized text is sent	User
UC-2	Receive a restored response	The AI service responds with pseudonyms; the extension replaces them with the original values while the response is streamed	User
UC-3	Send a request containing blocked data	The extension detects a data type with the policy "block", explains the reason and does not send the text	User
UC-4	Call a language model programmatically	A service account sends a request to the API proxy; the proxy anonymizes it, forwards it to the provider and restores the response	Service account
UC-5	Configure policies	The administrator selects the action for each data type and the services to which it applies	Administrator
UC-6	Review the log	The administrator or auditor filters log records and exports them; original values are not shown	Administrator, auditor

6. Functional Requirements

Priorities follow the MoSCoW method: *Must* requirements form the minimum viable product for the first release; *Should* requirements are planned for the final version; *Could* requirements are implemented if time allows. Each requirement has an acceptance criterion that is verified in the evaluation (see the document *Evaluation Plan*).

Missed personal data cannot be recalled once sent, whereas a false alarm only costs the user one click; however, frequent false alarms lead users to confirm without reading. Detection quality is therefore evaluated primarily by recall and by the F2 score, which weights recall twice as much as precision, under a minimum precision constraint. This also follows the user survey, in which 51% of respondents preferred detecting all personal data even with occasional false alarms.

Table 5: Functional requirements

ID	Requirement	Priority	Acceptance criterion
FR-1. Detection of personal data			
FR-1.1	The system shall detect the data types in Table 3 in Kazakh, Russian and English text	Must	Recall ≥ 0.95 and precision ≥ 0.95 for structured identifiers (IIN/BIN, phone, e-mail, card, IBAN) on the test corpus
FR-1.2	The system shall detect names, addresses and organizations in each of the three languages	Must	Recall ≥ 0.85 and precision ≥ 0.80 for each language; F2 higher than the Presidio baseline
FR-1.3	The system shall detect personal data in mixed-language (code-switched) text	Must	Recall on the code-switched subset not lower than 0.05 below the average of the three languages
FR-1.4	The system shall return, for each detection, the type, the position in the text and a confidence score	Must	Present in every API response
FR-2. Validation of identifiers			
FR-2.1	IIN and BIN shall be validated by the check digit; IIN also by the date of birth	Must	No detections on 100 synthetic numbers with an invalid check digit
FR-2.2	Bank card numbers shall be validated by the Luhn algorithm and IBAN by the IBAN checksum	Must	No detections on 100 invalid synthetic numbers of each type
FR-3. Pseudonymization			
FR-3.1	Detected values shall be replaced with typed pseudonyms (`<PERSON_1>`, `<IIN_1>`, ...)	Must	Anonymized text contains no detected original values
FR-3.2	The same entity shall receive the same pseudonym within a request, including different word forms of a name (for example, “Ivanov”, “Ivanova”, “Ivanovu”)	Must	100% consistency on test texts with repeated entities

Table 5 (continued)

ID	Requirement	Priority	Acceptance criterion
FR-3.3	The mapping shall be stored on the server for the duration defined in NFR-2 and shall be available only to the request that created it	Must	Mapping is not accessible with another session token
FR-4. Restoration of responses			
FR-4.1	Pseudonyms in the AI response shall be replaced with the original values	Must	At least 95% of test responses fully restored
FR-4.2	Restoration shall work for streamed responses, including pseudonyms split between fragments	Must	No unrestored or broken pseudonyms in streamed test responses
FR-4.3	Restoration shall tolerate inflected pseudonyms (for example, a suffix added by the model)	Should	At least 90% of inflected pseudonyms restored
FR-4.4	The user shall be able to view the response as the AI service received it	Could	Switch available in the response view
FR-5. Browser extension			
FR-5.1	The extension shall intercept text before it is sent in the web interfaces of ChatGPT and Gemini	Must	Works in both services on the current version of their interfaces
FR-5.2	The extension shall highlight detected data and show them in a review list with type, value and pseudonym; detections below the confidence threshold shall be shown as suggestions that are not marked by default	Must	All detections are shown before sending; low-confidence detections visually distinguished
FR-5.3	The user shall be able to unmark a detection, change its type and mark missed data manually	Must	Each action is reflected in the anonymized text
FR-5.4	The user shall be able to preview the text that the AI service will receive	Should	Preview available before sending
FR-5.5	The extension shall support two modes: review before sending (default) and automatic replacement, if allowed by the administrator	Must	Mode switch in the extension window
FR-5.6	The user shall sign in with an organization account; the extension shall work only with the organization's server	Must	Requests without a valid token are rejected
FR-5.7	The extension interface shall be available in Kazakh, Russian and English	Should	All screens translated

Table 5 (continued)

ID	Requirement	Priority	Acceptance criterion
FR-6. Processing policies			
FR-6.1	For each data type, the administrator shall select one action: replace, warn (replace after explicit confirmation) or block sending; blocking is triggered only by detections validated by a checksum or with high confidence	Must	The selected action is applied in the extension and the API proxy
FR-6.2	When sending is blocked, the user shall see which data type caused the block	Must	Message names the data type
FR-6.3	The administrator shall select the services (ChatGPT, Gemini, API proxy) to which policies apply and whether users may choose the automatic mode	Should	Settings applied without restarting the extension
FR-7. Administration, log and statistics			
FR-7.1	Each check shall be recorded in a log with time, user, service, data types, number of values and action, without original values	Must	No original values in the log on the test corpus
FR-7.2	The administrator and auditor shall be able to filter the log by period, data type and action and export it to CSV	Should	Filters and export available
FR-7.3	The administration panel shall show statistics: number of checks, hidden values, blocked requests, distribution by type and average latency	Should	Statistics for 7 days, 30 days and a quarter
FR-7.4	The administrator shall manage users and assign the roles in Table 2	Must	Role restrictions enforced by the server
FR-7.5	The administrator shall configure the mapping retention period, the behaviour on failure and the NER confidence threshold	Should	Settings applied to new requests
FR-8. API proxy			
FR-8.1	The system shall provide an endpoint that anonymizes text and returns the anonymized text and detections	Must	Endpoint documented in OpenAPI

Table 5 (continued)

ID	Requirement	Priority	Acceptance criterion
FR-8.2	The system shall provide a proxy compatible with the OpenAI and Gemini chat interfaces, including streaming, which anonymizes the request and restores the response	Should	An unmodified OpenAI client library works through the proxy
FR-8.3	Provider keys shall be stored on the server and never sent to clients	Must	No provider key in client traffic

Table 6 (continued)

ID	Quality	Requirement	Metric

7. Non-Functional Requirements

Table 6: Non-functional requirements

ID	Quality	Requirement	Metric
NFR-1	Performance	Anonymization shall not noticeably delay the request	At most 1 s (95th percentile) for a text of up to 2,000 characters on a CPU server; restoration of a response at most 0.1 s
NFR-2	Security and privacy	Original values and the mapping shall not leave the organization; the mapping shall be encrypted and deleted automatically; original values shall not be written to logs; all traffic shall use HTTPS with token authentication	AES-256-GCM; mapping retention of at most 15 min (default 15 min); no original values in logs; JWT sessions expire after 30 min of inactivity
NFR-3	Deployability	The system shall be deployed on the organization's server	Started with a single Docker Compose command; no external services except the selected AI providers
NFR-4	Reliability	If the anonymization service is unavailable or does not respond in time, text shall not be sent unchecked (fail-closed); the administrator may switch to a warning mode	Sending is suspended when the server is stopped; timeout configurable (1, 3 or 5 s)
NFR-5	Usability	The review of detected data shall be quick and understandable	A new user completes UC-1 without help; task completion of at least 90% in user testing; SUS score of at least 70
NFR-6	Extensibility	Support for a new AI service shall be added as a separate extension adapter without changes to the server; new data types shall be added as recognizers	Claude adapter can be added without changing the detection core

Table 6 (continued)

ID	Quality	Requirement	Metric
NFR-7	Maintainability	Code shall be covered by automated tests and documented	At least 70% test coverage of the server; OpenAPI documentation generated automatically
NFR-8	Compliance	Processing shall follow the principles of the Law on Personal Data: minimization, limited retention and processing within the organization [1]	Requirements NFR-2 and FR-7.1 satisfied

8. Constraints and Assumptions

- Only text is processed; images, PDF files, audio and video are out of scope.
- The browser extension is developed for Chromium-based browsers (Manifest V3).
- Changes in the web interfaces of ChatGPT and Gemini may require updates of the extension adapters; the API proxy is the stable alternative.
- Detection quality is evaluated only on a synthetic corpus with fictitious identifiers in a valid format; real personal data are not used.
- The NER model must run on a CPU server without a graphics processor.
- Detection cannot be complete: the review step (FR-5.2, FR-5.3) and the policies (FR-6) reduce the risk of missed data but do not eliminate it. Quasi-identifiers and attribute inference [6] are not addressed by this system.

9. Requirements Derived from the User Survey

The survey results described in the document *Evidence of Relevance* refined several requirements (Table 7).

Table 7: Survey findings and resulting requirements

Finding	Requirement
71% of respondents use several languages or mix them in one prompt; 77% use Kazakh or mixed prompts	FR-1.1, FR-1.3: Kazakh, Russian, English and code-switched text
51% prefer detecting all personal data even with occasional false alarms	FR-1: recall-oriented evaluation (F2 with a minimum precision); FR-5.2: low-confidence suggestions; FR-5.3: manual marking of missed data
57% want to review and confirm detected data before sending; 14% prefer fully automatic replacement	FR-5.5: review mode by default, automatic mode as an option
89% accept an additional delay of at least 1–3 s	NFR-1: target of 1 s is sufficient
Claude is used by 63% of respondents	NFR-6: adapter-based architecture for new services
54% want a detection log and per-type rules; 50% consider processing within the organization important	FR-6, FR-7, NFR-2, NFR-3
Six respondents named concerns about confidentiality and trust in the tool itself	NFR-2: no original values in logs; encrypted, short-lived mapping

10. Traceability

Table 8 links the requirements to the project objectives, the screens of the user interface prototype and the technology decisions.

Table 8: Traceability matrix

Req.	Objective	Prototype screens	Technology decision
FR-1	3	U1, U6, U7	Hybrid detection: rules, XLM-R NER, gazetteer
FR-2	3	U1, A3	Custom Presidio recognizers with checksums
FR-3	4, 5	U2, U3	Redis mapping store
FR-4	4, 6	U4, P1	FastAPI streaming
FR-5	7	U1–U3, U6, U7, X1, X2	Browser extension (Manifest V3)
FR-6	7	U2, U5, A3	PostgreSQL (policies)
FR-7	5, 7	A1–A6	PostgreSQL (log, users)
FR-8	6	P1	REST over HTTPS, OpenAI-compatible proxy
NFR-1	—	U3, A2	FastAPI, encoder NER model
NFR-2	5	A4, A6, X2	Redis with expiry, AES, JWT
NFR-3	—	A6	Docker Compose
NFR-4	—	U8, A6	Extension fail-closed mode
NFR-5	7	U1–U8	—
NFR-6	—	X1, A6	Extension adapters

References

[1] Law of the Republic of Kazakhstan No. 94-V "On Personal Data and Their Protection", 21 May 2013 (current edition). [Online]. Available: https://adilet.zan.kz/rus/docs/Z1300000094

[2] C. J. Chong, C. Hou, Z. Yao, and S. M. S. Talebi, "Casper: Prompt sanitization for protecting user privacy in web-based large language models," in *Proc. IEEE 12th Int. Conf. on Cyber Security and Cloud Computing (CSCloud)*, 2025, pp. 122–131, doi: 10.1109/CSCloud66326.2025.00027.

[3] A. I. Asimine, F. Salhab Doria Ricardo, F. Torgo, G. Choudhary, and N. Dragoni, "PromptShield: Protecting user privacy in AI chatbots," *Software*, vol. 5, no. 2, art. 24, 2026, doi: 10.3390/software5020024.

[4] R. Yeshpanov, Y. Khassanov, and H. A. Varol, "KazNERD: Kazakh named entity recognition dataset," in *Proc. LREC*, 2022, pp. 417–426. [Online]. Available: https://aclanthology.org/2022.lrec-1.44

[5] Microsoft, "Presidio: Data protection and de-identification SDK," documentation. [Online]. Available: https://presidio.dataprivacystack.org/

[6] N. Lukas, A. Salem, R. Sim, S. Tople, L. Wutschitz, and S. Zanella-Béguelin, "Analyzing leakage of personally identifiable information in language models," in *Proc. IEEE Symposium on Security and Privacy*, 2023, pp. 346–363, doi: 10.1109/SP46215.2023.10179300.